보안 조치 결과 보고서 — 보석 맞추기 (jewel-game)

항목	내용
작성 일자	2026-11-07
근거 문서	보안 검토 보고서 `SECURITY_REVIEW.md` (KISA「AI 보안 위협 대응 매뉴얼」2026.7 기준)
조치 대상	로컬 작업본 (기준 커밋 `843f96c` + 미커밋 변경 10개 파일)
배포 상태	**미배포** — 변경 사항은 git에 커밋·푸시하지 않았으며, 운영 중인 Vercel 배포본에는 아직 반영되지 않음

1. 요약

보안 검토에서 나온 11건 중 **코드로 해결할 수 있는 6건을 반영**했다. 나머지는 콘솔 설정 변경이나 운영 절차라서 담당자 조치가 필요하다.

구분	건수	항목
조치 완료 (검증 완료)	3	F-03 의존성, F-07 보안 헤더, F-08 레거시 페이지
코드 반영 (DB 적용 대기)	3	F-01 점수 위·변조, F-05 개인정보(일부), F-06 요청 빈도
담당자 조치 필요	5	F-02, F-04, F-09, F-10, F-11

핵심 결과

- `npm audit` 결과: 조치 전 **7건(높음 4)** → 조치 후 **0건**
- 점수 저장 구조: 브라우저가 테이블에 직접 저장 → **서버 함수가 검증한 뒤에만 저장**
- 배포 응답 보안 헤더: HSTS 1종 → **6종** (CSP, X-Frame-Options 등 추가)

> **배포 전 필수 순서**: ① Supabase SQL Editor에서 `supabase/schema.sql` 실행 → ② 커밋·푸시(Vercel 자동 배포). 순서를 바꾸면 배포 직후 점수 저장이 실패한다.

2. 항목별 조치 내용

F-01 높음 점수 위·변조 — 코드 반영, DB 적용 대기

구분	조치 전	조치 후
저장 경로	브라우저 → `scores` 테이블 직접 INSERT	브라우저 → 서버 함수 `submit_score()` → `scores`
테이블 권한	로그인 사용자 INSERT 허용 (`scores_insert_own`)	정책 삭제, INSERT·UPDATE·DELETE 권한 회수
점수 검증	`0 ≤ score ≤ 1,000,000` 제약만	게임 세션 소유, 세션 1회 사용, 플레이 15초 이상·3시간 이내, 점수 1~20,000, 저장 간격 30초
게임 단위 식별	없음	판마다 `start_game()` 이 세션 ID 발급

구분	조치 전	조치 후
거부 기록	없음	`score_audit` 테이블에 사용자·세션·점수·사유 기록

- **변경 파일**: `supabase/schema.sql`, `src/services/scores.js` (`startGameSession`, `saveScore`가 `rpc()` 호출), `src/pages/GamePage.jsx` (판마다 세션 발급, 세션이 없으면 저장 버튼 비활성)
- **매뉴얼 대응**: 교육 시나리오 1의 취약 지점 *"API 호출 시 사용자 인증 절차, 스키마 확인 등의 검증 미흡"* 해소, 대응 방안 1.5 모니터링(거부 기록)
- **한계**: 점수 상한 안에서 조작한 값은 여전히 막지 못한다. 근본 대책인 "이동 기록을 서버에서 재계산"은 이번 범위에서 도입하지 않았다.

F-03 높음 의존성 취약점 — 조치 완료

패키지	조치 전	조치 후	비고
`react-router-dom`	6.28.0	**7.18.4**	6.30.6에도 보통 위험 2건이 남아 v7로 상향. 사용 API(`BrowserRouter`, `Routes`, `Navigate`, `useNavigate`)는 변경 없이 호환
`@supabase/supabase-js`	2.49.4	**2.118.0**	최신 2.119.0은 출시 3일째라 제외
`vite` (개발용)	5.4.11	**6.4.5**	개발 서버 경로 탐색 등 고위험 취약점 해소

- **선정 원칙**: 취약점이 해결된 버전 중 **출시 후 2주 이상 지난 버전**만 사용 (매뉴얼 [S03]·[S04], 대응 방안 2.2·2.3)
- **결과**: `npm audit` 전체 **0건**, `npm run build` 성공

F-05 중간 개인정보 — 일부 반영

구분	조치 전	조치 후
랭킹 닉네임	카카오 이름 그대로 공개	서버가 가림 처리해 저장 (`홍길동` → `홍*동`), 기존 기록도 일괄 가림
닉네임 출처	브라우저가 보낸 값	서버가 카카오 프로필(`auth.users`)에서 직접 가져옴 — 사칭 불가
처리 안내	없음	로그인 화면에 「개인정보 처리 안내」: 수집 항목, 이용 목적, 공개 범위, 보관·파기, 만 14세 미만 안내

- **변경 파일**: `supabase/schema.sql` (`mask_nickname()`), `src/pages/LoginPage.jsx`, `src/styles.css`
- **남은 작업**: Kakao 동의항목에서 이메일을 **선택 동의**로 변경 (콘솔)

F-06 중간 요청 빈도 제한 — 코드 반영, DB 적용 대기

- 점수 저장은 같은 사용자 기준 **30초에 1회**, 세션당 **1회**
- 게임 시작(세션 발급)은 **1분에 10회**까지, 하루 지난 세션은 자동 정리
- 화면 버튼에만 있던 제한을 **서버에서 강제**하도록 바뀌었다.

F-07 낮음 보안 헤더 — 조치 완료 (배포 후 재확인)

`vercel.json`에 다음 헤더를 추가했다.

헤더	값 (요약)	효과
`Content-Security-Policy`	스크립트·스타일은 자기 사이트만, 통신은 Supabase만, 이미지는 자기 사이트·카카오 CDN만, `frame-ancestors 'none'`	XSS 피해 제한, 외부 전송 차단
`X-Frame-Options`	`DENY`	클릭재킹 방지
`X-Content-Type-Options`	`nosniff`	파일 형식 위장 방지
`Referrer-Policy`	`strict-origin-when-cross-origin`	주소 정보 유출 최소화
`Permissions-Policy`	카메라·마이크·위치·결제 차단	불필요한 권한 차단

F-08 낮음 레거시 `jewel.html` — 조치 완료

- 외부 스크립트를 **supabase-js 2.118.0 npm 원본 파일**(`dist/umd/supabase.js`)로 교체하고 **SRI 해시**(`sha384-TcHR…yvgK`)와 `crossorigin="anonymous"`를 지정했다.
- jsDelivr의 `.min.js`는 CDN이 즉석에서 축소한 파일이라 npm 원본과 대조할 수 없으므로 사용하지 않았다.
- npm 패키지에서 꺼낸 파일과 CDN이 제공하는 파일의 해시가 **일치함을 확인**했다 (매뉴얼 대응 방안 2.2 무결성 검증).
- 게임 종료 화면의 `innerHTML`을 DOM 노드 구성으로 바꿨다.

3. 검증 결과

검증 항목	방법	결과
의존성 취약점	`npm audit`	0건
빌드	`npm run build`	성공
보안 헤더 적용	빌드 결과를 `vercel.json`과 같은 헤더로 로컬 서빙	헤더 5종 응답 확인, 로그인 화면 정상, 콘솔 오류·CSP 위반 없음
CSP 통신 제한	페이지 안에서 요청 시험	Supabase 요청 **허용**(200), 외부 사이트(example.com) **차단**
개인정보 안내	로그인 화면 확인	「개인정보 처리 안내」 표시
세션 미발급 시 동작	임시 사용자로 게임 화면 실행 (DB 함수 미생성 상태)	"게임 세션을 만들지 못해 점수를 저장할 수 없습니다" 안내, 저장 버튼 비활성
레거시 페이지 SRI	`jewel.html` 로드	스크립트 정상 로드(`window.supabase` 존재), 무결성 오류 없음

검증 항목	방법	결과
검증 후 정리	임시 테스트 파일 삭제, 테스트용 코드 원복	완료, 빌드 재확인

검증하지 못한 항목

- 서버 함수(`start_game`, `submit_score`)의 실제 동작: Supabase에 `schema.sql`이 아직 실행되지 않아 확인 불가
- 실제 카카오 로그인 상태의 저장·랭킹·닉네임 가림
- Vercel 배포본의 헤더: 배포하지 않았으므로 미확인

---

4. 변경 파일 목록 (미커밋)

파일	변경	관련 항목
`supabase/schema.sql`	직접 INSERT 차단, `game_sessions`·`score_audit` 테이블, `mask_nickname`·`start_game`·`submit_score` 함수, 실행 권한	F-01, F-05, F-06
`src/services/scores.js`	`startGameSession()` 추가, `saveScore()`를 서버 함수 호출로 변경	F-01
`src/pages/GamePage.jsx`	판마다 세션 발급, 세션 없으면 저장 비활성·안내	F-01
`src/pages/LoginPage.jsx`, `src/styles.css`	개인정보 처리 안내	F-05
`vercel.json`	보안 헤더 5종	F-07
`jewel.html`	supabase-js 2.118.0 + SRI, `innerHTML` 제거	F-03, F-08
`package.json`, `package-lock.json`	의존성 버전 상향	F-03
`PRD.md`	기술 스택 버전, SAV-2 서버 검증 방식, §7.3 변경 안내	문서
`SECURITY_REVIEW.md` / `.pdf`	6장「조치 결과」추가 (미추적 파일)	문서

---

5. 남은 조치 (담당자)

순위	ID	조치	위치
1	F-02	카카오 **Client Secret 재발급**(카카오 로그인·비즈니스 인증) 후 Supabase Kakao Provider에 새 값 입력	Kakao Developers, Supabase
2	F-01·F-06	`supabase/schema.sql` 전체 실행	Supabase SQL Editor
3	F-11	실행 후 `scores` 테이블 RLS 활성, 정책은 `scores_select_authenticated` 1개만 있는지 확인	Supabase Table Editor
4	—	변경 사항 커밋·푸시(배포) 후 응답 헤더·로그인·점수 저장 확인	GitHub, Vercel

순위	ID	조치	위치
5	F-05	이메일 동의항목을 **선택 동의**로 변경	Kakao Developers
6	F-09	Site URL을 `https://jewel-game-three.vercel.app`으로 변경	Supabase URL Configuration
7	F-04	에이전트 작업용 제한 토큰 사용, 고위험 설정 변경 사전 승인 규칙 수립	운영 절차
8	F-08·F-10	레거시 `jewel.html`·GitHub Pages 유지 여부 결정 (중단 시 Redirect URL도 삭제)	GitHub, Supabase

6. 배포 절차 (권장)

1. Supabase → **SQL Editor** → `supabase/schema.sql` 전체 붙여 넣고 **Run**
2. Supabase → **Table Editor** → `scores`에서 RLS·정책 확인 (F-11)
3. 변경 파일 커밋 후 GitHub에 푸시 → Vercel 자동 배포
4. 배포 후 확인
   - 응답 헤더: `curl -I https://jewel-game-three.vercel.app/`에 CSP 등 6종 표시
   - 카카오 로그인 → 게임 → 15초 이상 플레이 후 **점수 저장** 성공
   - 15초 안에 저장하거나 같은 판을 두 번 저장하면 거부 메시지 표시, `score_audit`에 기록
   - **점수 확인**에서 닉네임이 가려져 표시
5. 문제가 생기면 Vercel **Rollback**으로 이전 배포 복구 (DB 함수는 그대로 두어도 이전 앱과 충돌하지 않지만, 이전 앱은 직접 INSERT 권한이 없어 저장이 실패함)